Détection d'intrusion réseau explicable

Classification supervisée et explicable de flux réseau (CSE-CIC-IDS2018, infrastructure AWS) — Projet Challenge 1, Data Mining, ENSI 2026-2027 — Farah Grissa

Code : github.com/Farahgrissa/ids-xai-classification · **Application :** Streamlit Community Cloud · **API :** FastAPI (Hugging Face Spaces)

37 395	0,994	98 %	≈ 1 %	4 ms
flux analysés après nettoyage (27 % d'attaques)	PR-AUC de XGBoost sur un jeu de test jamais vu	des attaques détectées (rappel, seuil 0,5)	du trafic normal signalé à tort	pour classer 1 000 flux : compatible temps réel

PROBLÈME MÉTIER

Un centre opérationnel de sécurité (SOC) reçoit des millions de flux réseau par jour. Il lui faut un détecteur qui **repère les attaques sans noyer les analystes sous les fausses alertes**, et qui **justifie chaque alerte** pour qu'elle soit vérifiée en quelques secondes.

DONNÉES

- **CSE-CIC-IDS2018**, trafic capturé sur AWS, téléchargé automatiquement depuis le bucket S3 public.
- 3 familles d'attaques : **force brute** (FTP, SSH), **déni de service** (Hulk, SlowHTTPTest), **botnet**. Cible binaire : normal / attaque.
- **Qualité :** 21 % de doublons supprimés ; étiquettes incohérentes détectées (flux identiques étiquetés FTP et SlowHTTPTest).
- **Raccourcis exclus :** heure, port de destination et variables d'« empreinte système » (taille de fenêtre TCP), qui identifient la machine plutôt que le comportement.

DÉMARCHE ET MEILLEUR MODÈLE

Cinq modèles comparés en validation croisée stratifiée (5 plis), hyperparamètres optimisés (GridSearch, RandomizedSearch), critère **PR-AUC** adapté au déséquilibre des classes.

Modèle (jeu de test)	PR-AUC	Rappel	Précision	ms / 1 000
XGBoost (retenu)	**0,994**	**0,982**	**0,973**	**4**
Random Forest	0,993	0,981	0,976	11
Arbre de décision	0,985	0,979	0,968	3
KNN	0,977	0,978	0,970	53
Régression logistique	0,898	0,960	0,815	4

XGBoost égale Random Forest en performance, prédit 2 à 3 fois plus vite et ne surapprend pas (écart validation / test $< 0{,}003$, donc aucune fuite de données).

RÉSULTATS EN CONDITIONS RÉELLES

Sur le test, XGBoost manque environ 37 attaques sur 2 043, principalement des DoS Hulk dont le serveur saturé ne répond plus (flux vides, proches de connexions normales interrompues).

> **Effet du taux de base.** Le test contient 27 % d'attaques, un vrai réseau moins de 1 %. À taux de fausses alertes égal, la précision passe alors de 97 % à **environ 50 %** : une alerte sur deux serait fausse. Relever le seuil de 0,5 à 0,9 n'apporte que quelques points de précision et double le nombre d'attaques manquées.

EXPLICATIONS CLÉS

- **Taille des paquets** (variable la plus discriminante) : 52 % d'attaques parmi les flux à paquets de moins de 65 octets, 3 % au-delà de 161 octets. Les attaques envoient des paquets vides ou minimes.
- **Durée du flux** : 68 % d'attaques entre 1 et 27 ms, à peine 1 % au-delà de 1,6 s. Les outils automatisés ouvrent, envoient et coupent ; les utilisateurs gardent leurs connexions ouvertes.
- **Rythme** : un écart de l'ordre de la milliseconde entre paquets signale un outil automatisé (62 % d'attaques), une rafale de paquets un transfert normal (moins de 2 %).
- **Relations non linéaires** : le risque se concentre au milieu des plages de valeurs, ce qui explique l'avantage des modèles à base d'arbres.

Facteurs issus de l'analyse exploratoire et de l'analyse des erreurs ; leur poids dans chaque décision sera quantifié par SHAP (global et par flux) et LIME (module 5, en cours).

ANALYSE CRITIQUE

- **Variables sensibles et équité.** Aucune donnée personnelle n'est utilisée (adresses IP exclues). Le risque équivalent est l'**empreinte système** : une valeur de fenêtre TCP donne 100 % d'attaques car elle identifie la machine de l'attaquant ; la conserver ferait signaler des machines Linux légitimes. Elle est donc exclue.
- **Performance ou interprétabilité.** La régression logistique, lisible directement, perd 10 points de PR-AUC, produit **9 fois plus de fausses alertes** et ne détecte presque aucune attaque FTP ou SlowHTTPTest. Recommandation : **XGBoost accompagné d'explications par flux**, plutôt qu'un modèle simple mais inefficace.

RECOMMANDATIONS

- **Seuil de décision autour de 0,8**, ajusté à la capacité de traitement de l'équipe.
- **Agréger les alertes par source et par fenêtre de temps** : une attaque génère des centaines de flux, une fausse alerte est isolée.
- **Prioriser par score** et afficher l'explication de chaque alerte pour accélérer la vérification.
- **Recalibrer sur le trafic réel** de l'organisation avant toute mise en production, puis surveiller la dérive.

LIMITES

- Données de laboratoire : attaques automatisées, lancées depuis peu de machines.
- Taux d'attaques irréaliste : la précision mesurée est optimiste.
- Classification flux par flux : la répétition, signature de la force brute, n'est pas exploitée.
- Aucune attaque UDP ni attaque inconnue dans l'échantillon : capacité de généralisation non démontrée.